

Security Mindset & Attacker Thinking

Week 1



Let's reflect on assigned reading: What did you learn?

Most breaches don't start with a hacker. They start with a decision.

*2020: A Twitter employee received a phone call.
The caller said they were from IT.
The employee handed over their credentials.*

The result:

- 130 accounts targeted
- 45 tweeted from
- 36 DM inboxes accessed



The attacker didn't break anything. They walked in with stolen keys.

Attackers think in systems. Builders think in features.

Builder asks	Attacker asks
How does this feature work?	What happens if I misuse it?
Who is supposed to use this?	Who else can reach this, and how?
What does success look like?	What does failure look like, and can I cause it?
How do I get data in?	How do I get data out that I shouldn't have?

The CIA triad is the foundation of every security decision

Three properties. Every security control protects at least one.

Confidentiality

Only the right people can see the data

Examples

Encryption · access controls · need-to-know

Integrity

Data has not been altered without authorization

Examples

Hashing · digital signatures · audit logs

Availability

Systems are accessible when needed

Examples

Redundancy · backups · DDoS mitigation

The CIA triad looks different depending on your role

Role	Confidentiality	Integrity	Availability
Developer	Is sensitive data exposed in API responses or logs?	Can input corrupt data or logic?	Does the app fail safely under load or bad input?
IT Admin	Who has access to which systems and credentials?	Are configs drifting from known-good baselines?	Are services patched and running with failover?
QA Engineer	Is test data sanitized before use in staging?	Can test inputs trigger unexpected data changes?	Do error conditions degrade or crash the service?

How are you implementing Confidentiality, Integrity, and Availability (CIA) in your life or work today?

Threat modeling finds security problems before attackers do

- What are we building? — map the system and its trust boundaries
- What can go wrong? — play “devil’s advocate”
- What are we going to do about it? — fix, accept, transfer, or monitor
- Did we do a good enough job? — validate that mitigations actually work

Anatomy of a simple attack: credential stuffing

Attacker goal: access user accounts without breaking anything

1. Acquire

Buy a list of email/password pairs leaked from a previous breach. Available on dark web forums.

2. Automate

Write a script that submits each credential pair to the login endpoint.

3. Exploit

For every pair that succeeds: access the account, scrape data, change the email and password.

4. Persist

Use the accounts for fraud, phishing, or resale.

Defenders don't need to be perfect. They need to raise the cost.

- Rate limit login attempts. Automated attacks need volume.
- Require MFA. A stolen password alone is not enough.
- Alert on anomalous logins: new geography, new device, odd timing.
- Notify users when a login succeeds from somewhere new.
- Log enough to reconstruct what happened. Attackers count on gaps.

Security mindset is a habit, not a checklist

Three questions. Apply them to any system, feature, or config change:

Who should NOT have access to this, and can they get it anyway?

→ *Confidentiality + access control*

What is the worst thing someone could do here with malicious intent?

→ *Attacker mindset*

Would I know if something went wrong, and would I know in time?

→ *Detectability is a security control*

Class activity: What can go wrong here? (10 min)

We review multiple scenarios. Apply attacker mindset to it.

For each scenario, answer:

1. Who shouldn't have access, and can they get it anyway?
2. What is the worst thing someone could do here with malicious intent?
3. What does failure look like, and can I cause it?
4. What data can I get out that I shouldn't have?

When time is up:

Paste one finding into the chat.
Be ready to explain it to the group.

Scenario A

Your system:

A comment box on a public blog

Users type a comment and click Post. The comment appears immediately below the article, visible to all visitors. No login required.

Answer these questions about your system:

1. Who shouldn't have access, and can they get it anyway?
2. What is the worst thing someone could do here with malicious intent?
3. What does failure look like, and can I cause it?
4. What data can I get out that I shouldn't have?

Hints to get started:

- What can someone type into the comment field besides a comment?
- Who sees this content, and when?
- Does the system validate or sanitize what goes in?
- Can a comment affect other users, not just the page?

Paste one finding into the chat. Be ready to explain it to the group.

Scenario B

Your system:

A password reset flow

User enters their email address. The system sends a reset link. Clicking the link lets them set a new password without knowing the old one.

Answer these questions about your system:

1. Who shouldn't have access, and can they get it anyway?
2. What is the worst thing someone could do here with malicious intent?
3. What does failure look like, and can I cause it?
4. What data can I get out that I shouldn't have?

Hints to get started:

- What happens if I request a reset for someone else's email?
- Does the reset link expire? Can it be reused?
- Can I request resets repeatedly with no limit?
- What happens to existing sessions when a password is reset?

Paste one finding into the chat. Be ready to explain it to the group.

Scenario C

Your system:

A file upload feature, any format accepted

Users upload files up to 10 MB. The system stores the file and shows a shareable download link. Any file type is accepted.

Answer these questions about your system:

1. Who shouldn't have access, and can they get it anyway?
2. What is the worst thing someone could do here with malicious intent?
3. What does failure look like, and can I cause it?
4. What data can I get out that I shouldn't have?
5. Which STRIDE categories apply? (S T R I D E)

Hints to get started:

- What happens if someone uploads a .php or .exe file?
- Where does the file go? Is it in a web-accessible directory?
- Can the download link be guessed or enumerated?
- What if the file is very large, or uploaded thousands of times?

Paste one finding into the chat. Be ready to explain it to the group.

Scenario D

Your system:

An internal HR login form

Employees log in with email and password to access payroll records, personal details, and org chart information.

Answer these questions about your system:

1. Who shouldn't have access, and can they get it anyway?
2. What is the worst thing someone could do here with malicious intent?
3. What does failure look like, and can I cause it?
4. What data can I get out that I shouldn't have?
5. Which STRIDE categories apply? (S T R I D E)

Hints to get started:

- What stops an attacker from trying thousands of passwords?
- Is there a second factor required beyond the password?
- What happens after a successful login from an unusual location?
- Who can access the data once logged in, and can they export it?

Paste one finding into the chat. Be ready to explain it to the group.

Scenario E

Your system:

User profile API: GET /api/users/:id

The endpoint returns name, email, address, and account balance for a given user ID. The app calls it to display the current user's profile page.

Answer these questions about your system:

1. Who shouldn't have access, and can they get it anyway?
2. What is the worst thing someone could do here with malicious intent?
3. What does failure look like, and can I cause it?
4. What data can I get out that I shouldn't have?
5. Which STRIDE categories apply? (S T R I D E)

Hints to get started:

- What happens if I change :id to a different user's ID?
- Does the response include fields the caller doesn't need?
- Is authentication enforced on this endpoint?
- What could I learn by calling this 10,000 times with different IDs?

Paste one finding into the chat. Be ready to explain it to the group.

Key takeaways

- CIA triad (Confidentiality, Integrity, Availability): the lens for every security decision
- Attackers think about misuse. Defenders have to think the same way before building.
- Technical roles make security decisions daily. You are the first line of defense.
- Security mindset: who shouldn't access this, what's the worst case, will I know if it fails?

Lab & next week

Complete before next lecture:

1. Start Here (Intro):

<https://www.youtube.com/watch?v=z5lpHsl8qQ4>

2. Hashing:

<https://www.youtube.com/watch?v=b4b8ktEV4Bg>

3. End to End Encryption:

<https://www.youtube.com/watch?v=DXv1boalsDI>

4. COMPLETE: Quiz on Google Classroom.

Coming up: Week 2 — Cryptography Fundamentals

- Hashing vs. encryption vs. signing
- Symmetric vs. asymmetric cryptography
- TLS, PKI, certificates
- Where crypto breaks in practice